

RAPORT KOŃCOWY - Pełny Test Bezpieczeństwa Hosta 192.168.1.1

Data wykonania: 2026-07-18, godz. 05:40 - 05:58 CEST

Wykonał: Agent główny + Agent Hacker

Adres docelowy: 192.168.1.1

Typ testu: Pełny test bezpieczeństwa (vulnerability assessment + penetration test)

1. STRESZCZENIE WYKONAWCZE

Przeprowadzono pełny test bezpieczeństwa hosta 192.168.1.1, który jest routerem **MikroTik RouterOS v6.49.20** (MAC: B8:69:F4:71:50:10, Routerboard.com). Host jest osiągalny bezpośrednio w sieci LAN (1 hop, avg RTT 5.5ms) i rozwiązuje się jako `router.office.local`.

Ogólna ocena bezpieczeństwa: ŚREDNIA-WYSOKA RYZYKO (3 krytyczne, 3 wysokie, 4 średnie, 3 niskie znaleziska)

Kluczowe znaleziska:

- 1 potwierdzona podatność CVE** (CVE-2026-7668, HIGH 7.3)
- Telnet aktywny** (krytyczne - hasła w czystym tekście)
- FTP aktywny** (wysokie - hasła w czystym tekście)
- DNS Recursion publicznie dostępna** (wysokie - DNS amplification)
- Brak HTTPS** (wysokie - WebFig bez szyfrowania)
- 7 otwartych portów TCP + 3 UDP**

2. IDENTYFIKACJA HOSTA

Parametr	Wartość
Adres IP	192.168.1.1
Nazwa DNS	router.office.local
Adres MAC	B8:69:F4:71:50:10
Producent	Routerboard.com (MikroTik)
System	RouterOS v6.49.20
CPE	cpe:/o:mikrotik:routeros:6.49.20
Nazwa hosta (FTP banner)	"ruter"
Dostępność	Host osiągalny (0% packet loss)

3. SKANOWANIE PORTÓW

3.1 Otwarte porty TCP (7)

Port	Usługa	Wersja/Banner	Ryzyko
21/tcp	FTP	MikroTik 6.49.20 FTP ("ruter FTP server")	WYSOKIE
22/tcp	SSH	SSH-2.0-ROSSH (RSA 2048, DSA 1024)	ŚREDNIE
23/tcp	Telnet	MikroTik Telnet	KRYTYCZNE
53/tcp	DNS	MikroTik DNS	ŚREDNIE
80/tcp	HTTP	MikroTik WebFig (RouterOS v6.49.20)	WYSOKIE
2000/tcp	Nieznany	Usługa binarna MikroTik (cisco-sccp)	NISKIE
8291/tcp	Winbox	MikroTik Winbox (roteros.dll 6.49.20)	ŚREDNIE

3.2 Otwarte porty UDP (3 potwierdzone)

Port	Usługa	Status	Ryzyko
53/udp	DNS	Otwarty	WYSOKIE
67/udp	DHCP Server	Otwarty Filtrowany	NISKIE
68/udp	DHCP Client	Otwarty Filtrowany	NISKIE

3.3 Dodatkowe porty UDP (open | filtered - 19 portów)

Porty: 37, 69, 135, 139, 162, 500, 1032, 1038, 1039, 1045, 2002, 2967, 3052, 32815, 34555, 49154, 49163, 49182, 49191

3.4 Zamknięte porty (negatywne wyniki)

- 443/tcp (HTTPS) - ZAMKNIĘTY
 - 445/tcp (SMB) - ZAMKNIĘTY
 - 139/tcp (NetBIOS) - ZAMKNIĘTY
 - 161/udp (SNMP) - ZAMKNIĘTY
 - 1900/udp (UPnP) - ZAMKNIĘTY
 - 123/udp (NTP) - ZAMKNIĘTY
 - 20561/udp (MAC-Telnet) - ZAMKNIĘTY
-

4. SZCZEGÓŁOWA ANALIZA USŁUG

4.1 FTP (Port 21)

- **Banner:** 220 ruter FTP server (MikroTik 6.49.20) ready
- **System:** SYST: UNIX MikroTik 6.49.20
- **Logowanie anonimowe:** ODRZUCONE (331 Password required → 530 Login incorrect)
- **Test domyślnych haseł:** admin, root, user, mikrotik - wszystkie odrzucone (530 Login incorrect)
- **Zagrożenie:** FTP przesyła dane i hasła w czystym tekście (brak FTPS/SFTP)

4.2 SSH (Port 22)

- **Banner:** SSH-2.0-ROSSSH
- **Klucze:** RSA 2048-bit (83:9f:7c:8c:14:b8:4a:f1:d8:bd:37:8c:1b:e2:f7:e5), DSA 1024-bit (b3:07:ee:4f:bf:9a:da:d3:65:6c:26:79:ed:c1:bf:be)
- **Logowanie domyślne (admin):** Permission denied (publickey,password)
- **Zagrożenie:** Klucz DSA 1024-bit jest przestarzały i nie zalecany przez NIST

4.3 Telnet (Port 23)

- **Status:** Aktywny, odpowiada na połączenia
- **Protokół:** Odpowiedź binarna (niestandardowy protokół MikroTik)
- **Zagrożenie:** KRYTYCZNE - Telnet przesyła wszystkie dane w czystym tekście, w tym hasła administracyjne. Atakujący w sieci LAN może przechwycić poświadczenia (sniffing).

4.4 DNS (Port 53 TCP/UDP)

- **Rekurencja DNS:** WŁĄCZONA - serwer rozwiązuje zapytania dla dowolnych domen (test: google.com → pełna odpowiedź z 6 adresami IP)
- **DNS Amplification:** Zapytanie DNSKEY zwróciło 1069 bajtów vs ~40 bajtów zapytania = współczynnik amplifikacji ~26x
- **Zone Transfer (AXFR):** ODRZUCONE (Transfer failed) - DOBRE
- **version.bind CHAOS TXT:** NOTIMP (nie ujawnia wersji) - DOBRE
- **Zagrożenie:** Otwarta rekurencja DNS może być wykorzystana do DNS amplification DDoS attacks

4.5 HTTP / WebFig (Port 80)

- **Serwer:** MikroTik RouterOS WebFig
- **Tytuł:** "RouterOS router configuration page"
- **Wersja:** RouterOS v6.49.20 (ujawniona na stronie)
- **Panel logowania:** WebFig Login dostępny, domyślnie uzupełnione pole "admin"
- **robots.txt:** `User-agent: * / Disallow: /` (ujawnia istnienie panelu)
- **Dostępne ścieżki:**
 - `/` - Strona logowania WebFig (200 OK)
 - `/webfig/` - Panel WebFig (406 Not Acceptable bez odpowiednich nagłówków)
 - `/winbox` - Pobieranie Winbox (200 OK)
 - `/graphs` - Wykresy ruchu (303 → strona grafów)
 - `/robots.txt` - Robots (200 OK)
 - `/help/license.html` - Licencja (200 OK)
- **Metody HTTP:** GET, POST obsługiwane; OPTIONS → 503 unknown method
- **Nagłówki bezpieczeństwa:** BRAK (brak X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security, Content-Security-Policy)
- **REST API:** NIEDOSTĘPNE (404 - typowe dla RouterOS v6)
- **Zagrożenie:** Panel administracyjny bez szyfrowania, brak HTTPS

4.6 Port 2000/TCP

- **Odpowiedź:** 4 bajty danych binarnych (`01 00 00 00`)
- **Klasyfikacja nmap:** cisco-sccp
- **Prawdopodobna funkcja:** Wewnętrzna usługa MikroTik (nie standardowy SCCP)
- **Zagrożenie:** NISKIE

4.7 Winbox (Port 8291)

- **Status:** Otwarty, aktywny

- **Wersje DLL:** roteros.dll 6.49.20, secure.dll 6.49.20, system.dll 6.49.20, dhcp.dll 6.49.20, ppp.dll 6.49.20, rotating4.dll 6.49.20, mpls.dll 6.49.20, hotspot.dll 6.49.20, wlan6.dll 6.49.20, advtool.dll 6.49.20
- **Test protokołu:** Brak odpowiedzi na podstawowy handshake (protokół własnościowy)
- **Zagrożenie:** ŚREDNIE - Winbox dostępny bez ograniczeń IP

4.8 SCEP Endpoint

- **URL:** `http://192.168.1.1/scep`
- **Odpowiedź:** HTTP 406 Not Acceptable (endpoint istnieje, ale wymaga specyficznych nagłówków)
- **Status:** AKTYWNY - endpoint SCEP jest dostępny
- **Zagrożenie:** POWIĄZANE Z CVE-2026-7668

5. PODATNOŚCI CVE

5.1 CVE-2026-7668 - POTWIERDZONY (HIGH)

Parametr	Wartość
CVE	CVE-2026-7668
Opis	Out-of-bounds read w SCEP endpoint
Komponent	nova/lib/www/scep.p, funkcja ASN1STRINGdata
CVSS 3.1	7.3 HIGH (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L)
CVSS 4.0	5.5 MEDIUM
Dostęp	Remote, unauthenticated
Parametry ataku	transactionID, messageType
Wersja bazowa	RouterOS 6.49.8
Wersja hosta	6.49.20
Status endpointu	AKTYWNY (HTTP 406 zamiast 404)
Rekomendacja	Upgrade do najnowszej wersji v6.x lub v7.x

Opis: Podatność typu out-of-bounds read w bibliotece SCEP (Simple Certificate Enrollment Protocol). Zdalny, nieuwierzytelniony atakujący może wyzwolić odczyt poza granicami bufora, potencjalnie ujawniając zawartość pamięci lub powodując awarię usługi. Atakujący manipuluje parametrami `transactionID` i `messageType` w żądaniach SCEP.

5.2 CVE-2023-30799 - NIE PODATNY

Parametr	Wartość
CVE	CVE-2023-30799
Opis	Privilege escalation (admin → super-admin)
CVSS	9.1 CRITICAL
Wersje podatne	Stable < 6.49.7, Long-term ≤ 6.48.6
Wersja hosta	6.49.20
Status	✅ NIE PODATNY (6.49.20 > 6.49.7)

5.3 CVE-2024-54772 - NIE PODATNY

Parametr	Wartość
CVE	CVE-2024-54772
Opis	Winbox user enumeration via response size
CVSS	5.4 MEDIUM
Wersje podatne	< 6.49.18 i < 7.18
Wersja hosta	6.49.20
Status	✅ NIE PODATNY (6.49.20 > 6.49.18)

5.4 CVE-2024-27686 - NIE PODATNY

Parametr	Wartość
CVE	CVE-2024-27686
Opis	SMB DoS (device crash)
Wersje podatne	6.40.5 - 6.49.10
Port 445 (SMB)	ZAMKNIĘTY
Status	✅ NIE PODATNY (port zamknięty + wersja > 6.49.10)

5.5 CVE-2018-14847 - NIE PODATNY

Parametr	Wartość
CVE	CVE-2018-14847
Opis	Winbox directory traversal (file read/write)
Wersje podatne	$\leq 6.42.7$
Wersja hosta	6.49.20
Status	✅ NIE PODATNY (6.49.20 > 6.42.7)

6. ZAGROŻENIA KONFIGURACYJNE

6.1 KRYTYCZNE

Z1: Telnet aktywny (Port 23/TCP)

- **Opis:** Usługa Telnet jest aktywna i dostępna. Telnet przesyła wszystkie dane, w tym hasła administracyjne, w czystym tekście.
- **Ryzyko:** Atakujący w sieci LAN może przechwycić poświadczenia administracyjne poprzez sniffing (np. tcpdump, Wireshark).
- **Rekomendacja:** Wyłączyć Telnet: `/ip service disable telnet`

Z2: CVE-2026-7668 - SCEP OOB Read

- **Opis:** Podatność out-of-bounds read w SCEP endpoint, umożliwiającą zdalnemu atakującemu odczyt pamięci lub DoS.
- **Ryzyko:** Ujawnienie informacji, awaria usługi.
- **Rekomendacja:** Zaktualizować RouterOS do najnowszej wersji v6.x lub v7.x. Jeśli SCEP nie jest potrzebny - wyłączyć usługę.

6.2 WYSOKIE

Z3: FTP aktywny (Port 21/TCP)

- **Opis:** FTP przesyła dane i hasła w czystym tekście.
- **Ryzyko:** Przechwycenie poświadczeń przez atakującego w sieci LAN.
- **Rekomendacja:** Wyłączyć FTP jeśli nie jest potrzebny: `/ip service disable ftp`. Alternatywnie używać FTPS lub SFTP.

Z4: DNS Recursion publicznie dostępna

- **Opis:** Serwer DNS rozwiązuje zapytania rekursywne dla dowolnych domen, dla dowolnego zapytującego.
- **Ryzyko:** DNS amplification attacks (współczynnik amplifikacji ~26x dla DNSKEY z DNSSEC). Atakujący może wykorzystać router do ataków DDoS.
- **Rekomendacja:** Ograniczyć rekurencję DNS tylko do zaufanych sieci: `/ip dns set allow-remote-requests=no` lub skonfigurować firewall aby blokować zapytania DNS z niezaufanych sieci.

Z5: Brak HTTPS (Port 443)

- **Opis:** Panel WebFig jest dostępny tylko przez HTTP (port 80) bez szyfrowania.
- **Ryzyko:** Przechwycenie poświadczeń administracyjnych podczas logowania do WebFig.
- **Rekomendacja:** Włączyć HTTPS: `/ip service enable www-ssl` z odpowiednim certyfikatem, lub wyłączyć dostęp HTTP do panelu: `/ip service disable www`.

6.3 ŚREDNIE

Z6: SSH z przestarzałym kluczem DSA 1024-bit

- **Opis:** SSH oferuje klucz DSA 1024-bit, który jest uważany za przestarzały (NIST SP 800-131A).
- **Ryzyko:** Potencjalne osłabienie bezpieczeństwa połączenia SSH.
- **Rekomendacja:** Wyłączyć DSA w SSH, używać tylko RSA 2048+ lub Ed25519.

Z7: Brak nagłówków bezpieczeństwa HTTP

- **Opis:** Serwer HTTP nie ustawia nagłówków bezpieczeństwa: X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security, Content-Security-Policy.
- **Ryzyko:** Clickjacking, MIME sniffing, ataki XSS.
- **Rekomendacja:** Skonfigurować nagłówki bezpieczeństwa (jeśli RouterOS na to pozwala).

Z8: Winbox dostępny bez ograniczeń IP

- **Opis:** Port Winbox (8291) jest otwarty dla wszystkich adresów IP.
- **Ryzyko:** Atakujący w sieci LAN może próbować bruteforce lub innych ataków na panel zarządzania.
- **Rekomendacja:** Ograniczyć dostęp Winbox do zaufanych IP: `/ip service set winbox address=x.x.x.x/y`.

Z9: Ujawnienie wersji oprogramowania

- **Opis:** Router ujawnia wersję RouterOS (6.49.20) w wielu miejscach: HTTP, FTP, Winbox, DNS (via nmap).
- **Ryzyko:** Atakujący może zidentyfikować konkretne podatności dla tej wersji.
- **Rekomendacja:** Ograniczyć banner information gdzie możliwe (szczególnie FTP i HTTP).

6.4 NISKIE

Z10: Grafy ruchu dostępne bez autoryzacji

- **Opis:** Strona `/graphs` jest dostępna bez logowania i pokazuje wykresy ruchu sieciowego.
- **Ryzyko:** Ujawnienie informacji o wzorcach ruchu sieciowego.
- **Rekomendacja:** Wyłączyć graphing jeśli nie jest potrzebny: `/tool graphing disable`.

Z11: robots.txt ujawnia istnienie panelu

- **Opis:** `robots.txt` z `Disallow: /` ujawnia istnienie panelu zarządzania wyszukiwarkom.
- **Ryzyko:** Informacyjne - ułatwia identyfikację urządzenia.
- **Rekomendacja:** Usunąć robots.txt lub skonfigurować firewall aby blokować dostęp z Internetu.

Z12: Domyślne uzupełnione pole "admin" w WebFig

- **Opis:** Strona logowania WebFig domyślnie wpisuje "admin" w pole login.
- **Ryzyko:** Informacyjne - ujawnia domyślną nazwę użytkownika.
- **Rekomendacja:** Dodać własnego użytkownika i wyłączyć konto "admin".

7. POZYTYWNE ASPEKTY BEZPIECZEŃSTWA

Następujące elementy są prawidłowo skonfigurowane:

1.  **FTP anonymous login odrzucony** - wymaga uwierzytelnienia
 2.  **DNS zone transfer (AXFR) odrzucony** - nie ujawnia stref DNS
 3.  **DNS version.bind nie ujawnia wersji** (NOTIMP)
 4.  **SSH wymaga uwierzytelnienia** - domyślne hasła odrzucone
 5.  **WebFig wymaga logowania** - nie pozwala na dostęp bez poświadczeń
 6.  **SNMP wyłączony** (port 161/udp closed)
 7.  **UPnP wyłączony** (port 1900/udp closed)
 8.  **MAC-Telnet wyłączony** (port 20561/udp closed)
 9.  **SMB wyłączony** (port 445/tcp closed) - nie podatny na CVE-2024-27686
 10.  **Brak REST API** (typowe dla v6, nie ujawnia interfejsu API)
 11.  **Wersja RouterOS 6.49.20** - nie jest podatna na CVE-2023-30799, CVE-2024-54772, CVE-2018-14847
-

8. REKOMENDACJE - PLAN NAPRAWCZY

Priorytet KRYTYCZNY (natychmiast):

- 1. Wyłączyć Telnet: `/ip service disable telnet`
- 2. Zaktualizować RouterOS do najnowszej wersji v6.x lub v7.x (naprawa CVE-2026-7668)

Priorytet WYSOKI (w ciągu 24h):

- 1. Wyłączyć FTP lub zastąpić SFTP/FTPS: `/ip service disable ftp`
- 2. Wyłączyć DNS recursion dla niezaufanych sieci lub całkowicie: `/ip dns set allow-remote-requests=no`
- 3. Włączyć HTTPS dla WebFig: `/ip service enable www-ssl` + wyłączyć HTTP: `/ip service disable www`
- 4. Jeśli SCEP nie jest potrzebny - wyłączyć usługę SCEP

Priorytet ŚREDNI (w ciągu tygodnia):

- 1. Ograniczyć dostęp Winbox do zaufanych IP: `/ip service set winbox address=192.168.1.0/24`
- 2. Wyłączyć DSA w SSH - używać tylko RSA 2048+ lub Ed25519
- 3. Utworzyć dedykowane konto administratora z silnym hasłem i wyłączyć konto "admin"
- 4. Ograniczyć dostęp SSH do zaufanych IP: `/ip service set ssh address=192.168.1.0/24`

Priorytet NISKI (w miarę możliwości):

- 1. Wyłączyć graphing jeśli nie jest potrzebny: `/tool graphing disable`
- 2. Usunąć robots.txt lub zignorować (informacyjne)
- 3. Rozważyć migrację do RouterOS v7 - dłuższe wsparcie bezpieczeństwa, REST API, lepsze szyfrowanie

9. PODSUMOWANIE RYZYKA

Kategoria	Liczba	Szczegóły
Krytyczne	2	Telnet aktywny, CVE-2026-7668
Wysokie	3	FTP aktywny, DNS recursion, brak HTTPS
Średnie	4	DSA 1024, brak nagłówków HTTP, Winbox bez ograniczeń, ujawnienie wersji
Niskie	3	Graphs bez auth, robots.txt, domyślne "admin"
Razem	12	

Matryca ryzyka:

	Wpływ		
	Niski	Średni	Wysoki
Wysokie	[Z11]	[Z8]	[Z1, Z2, Z3, Z4, Z5]
Prawdop.	[Z10]	[Z6]	[Z7, Z9]
Niskie	[Z12]	[-]	[-]

10. ZAŁĄCZNIKI

Narzędzia użyte:

- **nmap 7.99** - skanowanie portów, NSE scripts, wykrywanie wersji
- **curl** - analiza HTTP, testowanie ścieżek i nagłówków
- **dig** - testy DNS (recursion, AXFR, version.bind, amplification)
- **nc (netcat)** - testy FTP, Telnet, portów
- **ssh** - test SSH (wersja, klucze, domyślne poświadczenia)
- **tracert** - analiza trasy
- **ping** - test osiągalności
- **python3** - test protokołu Winbox
- **search_web** - wyszukiwanie podatności CVE

Pliki raportów postępu:

- `postep_2026-07-18_05-40.md` - Inicjalizacja
- `postep_2026-07-18_05-52.md` - Skanowanie portów zakończone
- `postep_2026-07-18_05-55.md` - Analiza podatności w toku
- `postep_2026-07-18_05-57.md` - Znaleziono CVE-2026-7668
- `postep_2026-07-18_05-58.md` - Testy zakończone

Pliki skanowania Nmap:

- `nmap_tcp_fast_192.168.1.1.txt` - Szybki skan TCP (top 1000)
- `nmap_udp_top100_192.168.1.1.txt` - Skan UDP (top 100)
- `nmap_scripts_192.168.1.1.txt` - NSE scripts
- `nmap_vuln_192.168.1.1.txt` - Skan podatności

Raport wygenerowany: 2026-07-18 05:58 CEST

Test wykonali: Agent główny, Agent Hacker

Status testu: ZAKOŃCZONY